CYBER SECURITY

Vulnerability Assessment Report

Web Application Security Audit

Target Website

http://demo.testfire.net
(Altoro Mutual)

Prepared By

Khatri Mann Jatinkumar

Organization: Future Interns

1.EXECUTIVE SUMMARY

This Vulnerability Assessment Report presents the findings from a passive, read-only security audit conducted on http://demo.testfire.net, a demonstration banking web application operated by IBM (Altoro Mutual).

The assessment was performed strictly within ethical guidelines - no exploitation, brute force, or denial-of-service activities were performed.

The assessment identified 12 vulnerabilities across critical, high, and medium severity levels. These findings pose significant risks to the confidentiality, integrity, and availability of the application and its users' data.

2.SCOPE & METHODOLOGY

2.1 Target Information

Website	http://demo.testfire.net
Application	Altoro Mutual (IBM Demo Banking App)
IP Address	65.61.137.117
Server	Apache-Coyote/1.1
Assessment Type	Passive / Read-Only Vulnerability Assessment

2.2 Scope

- Public-facing pages only
- Passive scanning and header analysis
- Browser-based inspection (DevTools, Cookies)
- No login bypass, exploitation, or brute force

2.3 Tools Used

- SecurityHeaders.com – HTTP security header analysis
- Browser DevTools (Chrome) – Network & cookie inspection
- Manual testing – XSS and SQL Injection detection

2.4 Ethical Guidelines

This assessment strictly followed ethical guidelines as defined in the task scope. Only passive, read-only techniques were used. No data was modified, extracted, or damaged. The target site is an intentionally vulnerable demo application authorized for security testing.

3.VULNERABILITY FINDINGS

The following table summarizes all identified vulnerabilities, their risk classification, and the location where they were discovered.

Sr. Num	Vulnerability	Risk	Location	Category
1.	Missing Content-Security-Policy	High	Security Headers	Misconfiguration
2.	Missing X-Frame-Options	High	Security Headers	Misconfiguration
3.	Missing X-Content-Type-Options	Medium	Security Headers	Misconfiguration
4.	Missing Referrer-Policy	Medium	Security Headers	Misconfiguration
5.	Missing Permissions-Policy	Medium	Security Headers	Misconfiguration

Sr. Num	Vulnerability	Risk	Location	Category
6.	Server Version Disclosed	High	HTTP Response	Information Exposure
7.	No HTTPS Enforcement	High	Transport Layer	Insecure Transmission
8.	Missing SameSite Cookie Attribute	High	Session Cookie	Session Management
9.	Session Cookie Never Expires	High	Session Cookie	Session Management
10.	Cross-Site Scripting (XSS)	Critical	Search Box	Injection
11.	SQL Injection - Auth Bypass	Critical	Login Page	Injection
12.	Broken Access Control	Critical	Bank Pages	Access Control

4.DETAILED FINDINGS

Finding 10 - Cross-Site Scripting (XSS)

Vulnerability	Cross-Site Scripting (XSS)
Risk Level	Critical
Location	Search box - http://demo.testfire.net
OWASP Category	A03:2021 - Injection

Description: The website's search functionality does not sanitize user input. A malicious JavaScript payload injected into the search field was executed by the browser, confirming a reflected XSS vulnerability.

Proof Of Concept

Payload used:

<script>alert('This site is vulnerable!')</script>

Business Impact

- Attackers can steal session cookies and hijack user accounts
- Malicious scripts can redirect users to phishing sites
- Sensitive banking data can be captured and exfiltrated

Remediation

- Implement input validation and output encoding on all user inputs
- Deploy a Content Security Policy (CSP) header
- Use a Web Application Firewall (WAF)

Findings 11 - SQL Injection (Authentication Bypass)

Description: The login form is vulnerable to SQL injection. By entering a crafted SQL payload as the username, an attacker can bypass authentication entirely without knowing a valid password.

Proof Of Concept

Username: admin' or '10' = '10 **and** Password: 123456789

Vulnerability	SQL Injection - Authentication Bypass
Risk Level	Critical
Location	Login page - /bank/login.aspx
OWASP Category	A03:2021 - Injection

Business Impact

- Complete authentication bypass - anyone can log in as admin
- Full access to customer banking accounts and data
- Potential for database extraction, modification, or deletion

Remediation

- Use parameterized queries / prepared statements
- Never concatenate user input directly into SQL queries
- Implement input validation and least privilege database accounts

Findings 12 - Broken Access Control

Vulnerability	Broken Access Control
Risk Level	Critical
Location	/bank/ directory - multiple pages
OWASP Category	A01:2021 - Broken Access Control

Description: The website's search functionality does not sanitize user input. A malicious JavaScript payload injected into the search field was executed by the browser, confirming a reflected XSS vulnerability.

Business Impact

- Unauthorized access to sensitive banking functionality
- Violation of data privacy and compliance regulations
- Could expose customer financial information

Remediation

- Implement server-side authentication checks on all protected pages
- Redirect unauthenticated users to the login page
- Apply principle of least privilege across all routes

Findings 6 - Server Version Disclosed

Vulnerability	Server Version Information Disclosure
Risk Level	High
Location	HTTP Response Header -Server field
OWASP Category	Server: Apache-Coyote/1.1

Description

The server reveals its exact software and version (Apache-Coyote/1.1) in the HTTP response headers. This allows attackers to search for known vulnerabilities specific to that version.

Remediation

- Configure the server to suppress or obfuscate the Server header
- Upgrade server software to the latest stable version

5.SECURITY HEADER ANALYSIS

Security headers are HTTP response headers that instruct the browser on how to behave when handling the website's content. The following headers are missing from http://demo.testfire.net:

Missing Header	Risk	Impact
Content-Security-Policy	High	Allows XSS and code injection attacks
X-Frame-Options	High	Site can be embedded in iframes - Clickjacking risk
X-Content-Type-Options	Medium	Browser may misinterpret file types
Referrer-Policy	Medium	Sensitive URLs may leak to third-party sites
Permissions-Policy	Medium	Camera, microphone access not restricted

6.REMEDIATION RECOMMENDATION

The following remediation steps are prioritized by risk level. Critical and High issues should be addressed immediately.

Immediate Actions (Critical)

- Fix SQL Injection: Replace all dynamic SQL queries with parameterized queries or prepared statements
- Fix XSS: Implement input validation and output encoding on all user-controlled inputs
- Fix Broken Access Control: Add server-side authentication checks to all protected routes

Short-Term Actions (High)

- Enable HTTPS: Install an SSL/TLS certificate and enforce HTTPS across the entire site
- Add Security Headers: Implement Content-Security-Policy and X-Frame-Options headers
- Fix Session Management: Add SameSite=Strict attribute to all session cookies and implement session timeout

CONCLUSION

The security assessment of http://demo.testfire.net revealed a total of 12 vulnerabilities including 3 Critical, 6 High, and 3 Medium severity issues. The most severe findings - SQL Injection, Cross-Site Scripting, and Broken Access Control - represent fundamental security weaknesses that could lead to complete compromise of the application and its users' data in a real-world scenario.

The absence of basic security headers, lack of HTTPS enforcement, and insecure session management further compound the overall risk posture of the application.

It is strongly recommended that the development and security teams address all Critical and High severity findings immediately, followed by Medium severity issues in the next development cycle. A follow-up assessment should be conducted after remediation to verify that vulnerabilities have been properly resolved.

END OF REPORT

Prepared By

Cyber Security Intern | Future Interns | April 2026